

御杖村公式サイト セキュリティ改善提案書

対象URL: <https://www.vill.mitsue.nara.jp> 診断元: Internet.nl 診断結果: 約49% 作成日: 2026-06-04

Internet.nl の診断結果を基に評価した結果、HTTPS化は実施済みだが、DNSSEC・HSTS・TLS設定など複数の重要項目で改善余地がある。本提案書では検出された課題と推奨改善策を優先度別に示す。

優先度 A (早急対応推奨)

1. DNSSEC 未導入

問題点

- DNSキャッシュポイズニング
- 偽サイトへの誘導
- DNS応答の改ざん

推奨対応

DNS管理事業者へ依頼：

- DNSSECゾーン署名
- DSレコード登録

DNS改ざん防止 Internet.nlスコア向上

2. HSTS 未設定

問題点

攻撃者がHTTPSへの接続を妨害・HTTPへ誘導できる。

推奨対応

Webサーバーに追加：

```
Strict-Transport-Security:
  max-age=31536000;
  includeSubDomains
```

検証後は `preload` も検討。

HTTPS強制 SSL Stripping対策

3. 古いTLS暗号方式の許可

問題点

RSA鍵交換方式および一部CBC暗号が利用可能。旧方式を残すことで攻撃面が広がる。

有効化する暗号スイート

```
TLS 1.3:
  TLS_AES_256_GCM_SHA384
  TLS_CHACHA20_POLY1305_SHA256
  TLS_AES_128_GCM_SHA256
TLS 1.2:
  ECDHE-RSA-AES256-GCM-SHA384
  ECDHE-RSA-AES128-GCM-SHA256
  ECDHE-RSA-CHACHA20-POLY1305
```

無効化を推奨

```
RSA Key Exchange
CBC Cipher Suites
SHA1 Cipher Suites
```

Forward Secrecy向上 暗号強度向上

優先度 B (推奨)

4. SHA-1利用の排除

問題点

SHA-1は既に非推奨。

推奨対応

OpenSSL・ロードバランサ設定を見直し、以下のみ許可：

```
RSA+SHA256
ECDSA+SHA256
```

推奨ハッシュ：SHA-256 /
SHA-384 / SHA-512

5. Cipher Priority の見直し

問題点

暗号スイート優先順位の最適化が不足。クライアントによっては強度の低い暗号方式が選択される可能性。

推奨対応 (Apache)

```
SSLHonorCipherOrder on
```

6. OCSP Stapling 未設定

問題点

証明書失効確認のたびにブラウザが認証局へ問い合わせ → 表示速度・プライバシー低下。

推奨対応 (Apache)

```
SSLUseStapling On
SSLStaplingCache
shmcb:/var/run/ocsp(128000)
```

優先度 C (将来的改善)

7. DNSサーバのIPv6対応

状況

Webサイト本体はIPv6対応済み。権威DNSサーバがIPv6未対応。

推奨対応

DNS事業者へ依頼：AAAAレコード追加

8. HTTPセキュリティヘッダー強化

推奨設定

```
X-Frame-Options: SAMEORIGIN
X-Content-Type-Options: nosniff
Referrer-Policy: strict-origin-when-cross-origin
Permissions-Policy:
```

可用性向上 将来性向上

```
geolocation=(), camera=(),  
microphone=()
```

さらに `Content-Security-Policy` の導入も推奨。

クリックジャッキング対策 MIME偽装対策 XSS対策強化

推奨実施順序

第1段階

1. HSTS導入
2. TLS設定最適化
3. SHA-1排除
4. Cipher Priority

第2段階

1. DNSSEC導入
2. OCSP Stapling

第3段階

1. Security Header
強化
2. DNS IPv6対応

期待される効果

- Internet.nlスコア向上（49% → 80%以上見込み）
- HTTPS運用の強化
- DNS改ざんリスク低減
- 自治体サイトとしての信頼性向上
- 総務省・デジタル庁推進のセキュリティ水準への適合

参考資料

- Internet.nl — <https://internet.nl/>
- NLnet Labs — <https://www.nlnetlabs.nl/>
- OWASP Secure Headers Project — <https://owasp.org/www-project-secure-headers/>
- Mozilla SSL Configuration Generator — <https://ssl-config.mozilla.org/>
- RFC 4033 / 4034 / 4035 (DNSSEC) RFC 6797 (HSTS)